

AP Networking

Lesson 5.5 Defense in Depth

Security Event Case Study - Analysis and Recommendations

Part 1: Analyze a security event. Identify key details and how security was compromised.

Name of Security Event: Starwood Database Security Incident (Marriott International data breach)
Year of Incident: 2018
Industry Affected: Hotel industry

What security controls were in place? Data in Starwood's guest reservation system was 2FA encrypted (AES-128) Security systems were in place to alert of breaches or vulnerabilities
Where did these security measures fail? Cybercriminals used a remote access trojan to gain administrative access to Starwood devices. Cybercriminals were eventually able to locate their decryption keys and unlock the information. Outdated Windows OS system Left their remote desk protocol (RDP) ports open to the internet. Stolen information was re-encrypted in order to bypass system checks while being exported Hackers installed a RAT Unauthorized access since 2014
What were the impacts of this event? Up to 500 million people's information was leaked, including credit cards and passports. Marriott paid \$100-120 million in fees related to the incident. \$1B in damages. Multiple lawsuits filed, and paranoia in customers.

Identify the violations of the CIA triad in your case study. There might be more than one.

Security Principle	How was it compromised?	Specific Consequences
Confidentiality	RAT Trojan and infiltration to export stolen data	Credit cards, passport numbers, and other sensitive pieces of data were leaked

Integrity	Starwood failed to fix a credit card fraud event between 2015-2016, so when Marriott purchased it, it took the vulnerability with it	Reputation damage for Marriott. As well as financial loss for customers and stolen identities.

Part 2: Create recommendations to improve security to avoid events like this in the future.

Your recommendations should be in order from most critical (must have) to least critical (nice to have). Include physical, technical, and managerial controls to create your layered security plan.

Recommendation #1 Telling the public much sooner
Justification Failure of common sense: it should not take 11-12 weeks to let people know that their passports and credit cards may have been stolen
Feasibility (Cost, management, ease of implementation, etc.) Low cost, simple execution, super easy implementation
Priority Level (High, medium, low) Extreme

Recommendation #2 Update software on all devices.
Justification The outdated Windows OS contributed to the original vulnerability that was exploited in 2014.
Feasibility (Cost, management, ease of implementation, etc.) Super easy. Press a button to update to official builds of windows. Marriott can do what

PNNL does and doesn't update until the windows build is scanned for vulnerabilities and is determined to be safe.

Priority Level (High, medium, low)
High.

Recommendation #3

Close remote desk protocol ports to the internet.

Justification

The open RDP ports allowed the hackers to install a remote access trojan into the Starwood network.

Feasibility (Cost, management, ease of implementation, etc.)

Very easy. Just a couple of lines in the administrative command terminal.

Priority Level (High, medium, low)

High

Recommendation #4

Putting trojan detectors in the systems

Justification

Hackers planted a RAT into the system. This could've been prevented with proper detection systems.

Feasibility (Cost, management, ease of implementation, etc.)

Simple, medium cost, and you can just hire a company to do it for you.

Priority Level (High, medium, low)

High! We can't have more people in our systems